VULNHUB.COM Machine

SQL to Shell

MACHINE SECURITY TESTING AUDIT REPORT

Prepared By

Nikunj Kumar Sahani

NK REPORT BY NIKUNJ

Disclaimer

SQL Injection to Shell is a SQL injection hosted on **Pentesterlab**.

Document:	Machine Security Testing Report
Report Content:	Detailed Technical Report
Status:	**Completed**
Machine & IP:	Pentest Lab : SQL to Shell & 192.168.1.5

In this our main goal is to identify the SQL injection vulnerability, exploit that , it basically show how an **attacker** can use it to gain access to the **administration** page and run the commands on the system.

The VM is good for learning SQL injection exploitation and how to obtain shell access of a system by exploiting SQL Injection vulnerability.

This **vulnerable virtual machine** details the exploitation of an SQL injection vulnerability in a **PHP** based website.
Then, using administration access, the **attacker** will be able to gain code execution on the box.

The level of this virtual machine is **Easy** and is very good for beginners .

I am Tested this Vulnerable machine through Virtual Box.

Table of Contents

1. Ip Discover.....4
2. Scanning.....4-5
3. Web Server.....6
4. SQL Injection.....7
5. Enumerate : SQL Injection.....8-11
6. Finding the login page.....12
7. Log in.....13
8. Upload the Shell.....14-16
9. Root Access.....17
10. Done/Exit.....18

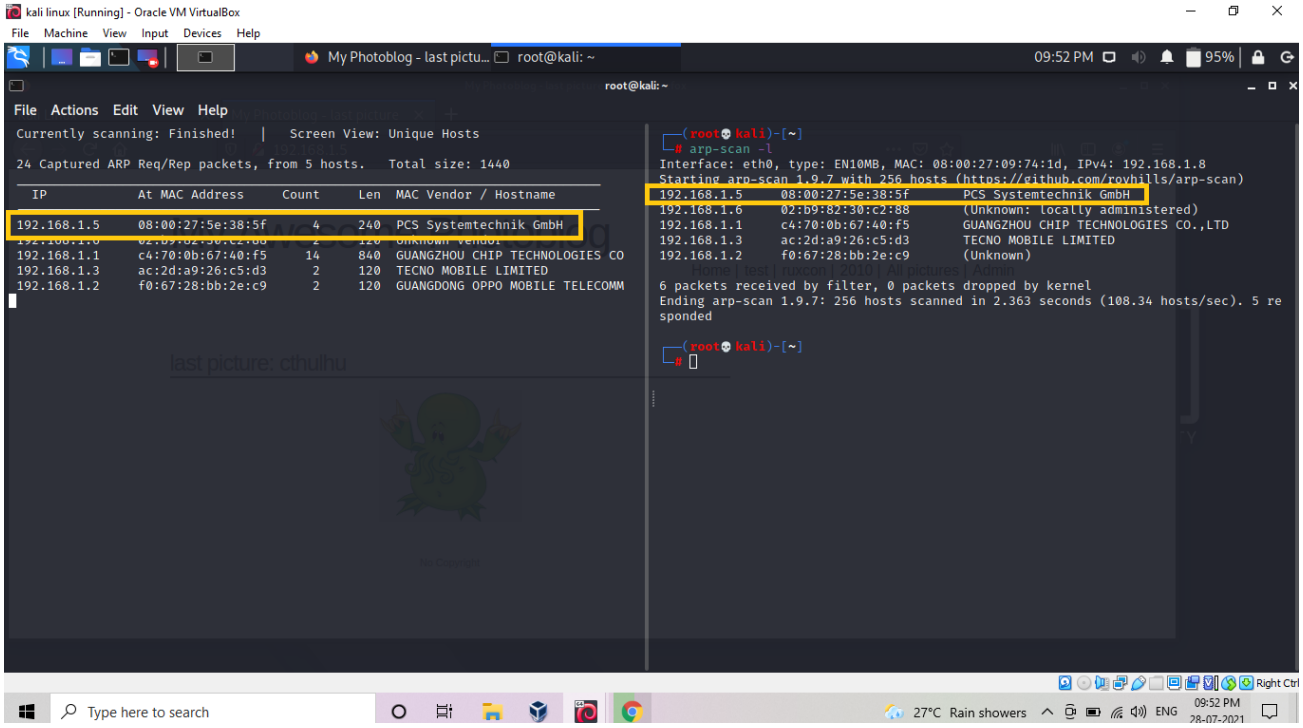
Detailed Vulnerability Information

The detailed explanation of the vulnerabilities as well as the recommendations for the same are explained below.

1. IP Discover

The attacking machine (**Kali**) which is on NAT also! We need to discover the **IP address** so we can start the **Game.**

cmd - 1. **netdiscover**
2. **arp-scan -l**



2. Scanning

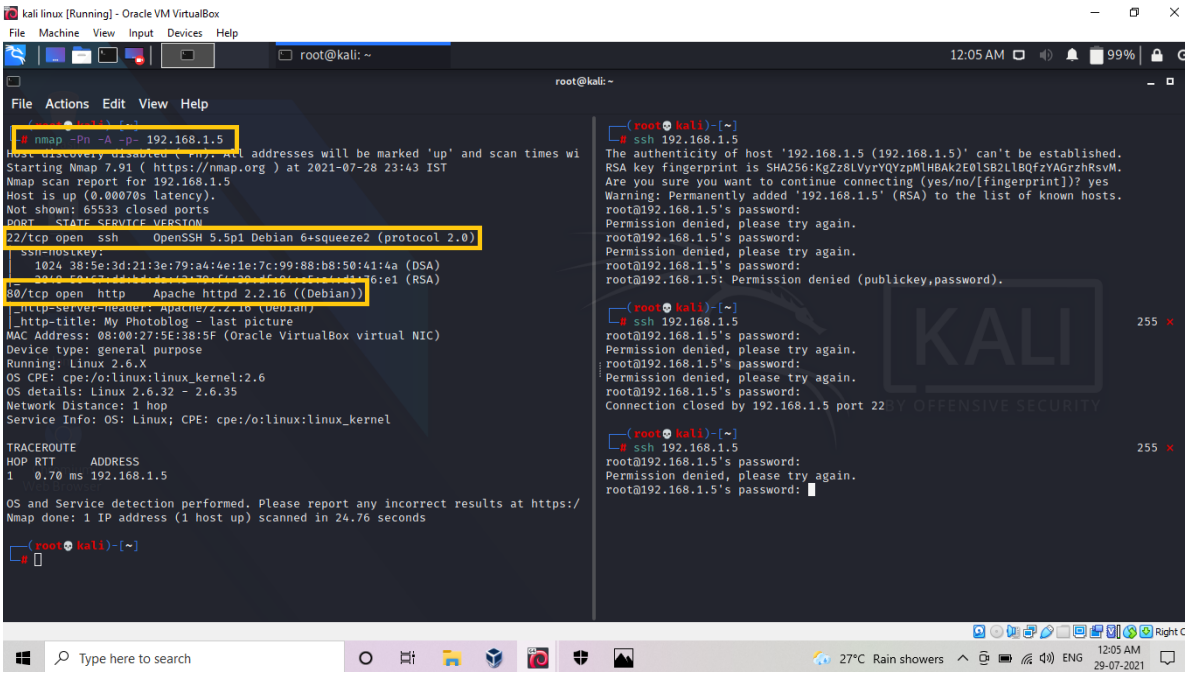
Let's Start

As always the real game starts with the **enumeration** part so I did **Nmap scan** first and found **Ports** are open or not.

Identify **services running** on From SQL Injection to Shell machine.

cmd- **nmap -Pn -A -p- 192.168.1.5**

Nmap the well known network scanner,
I used it to get the **open ports** so I can design my plan for attacking machine.

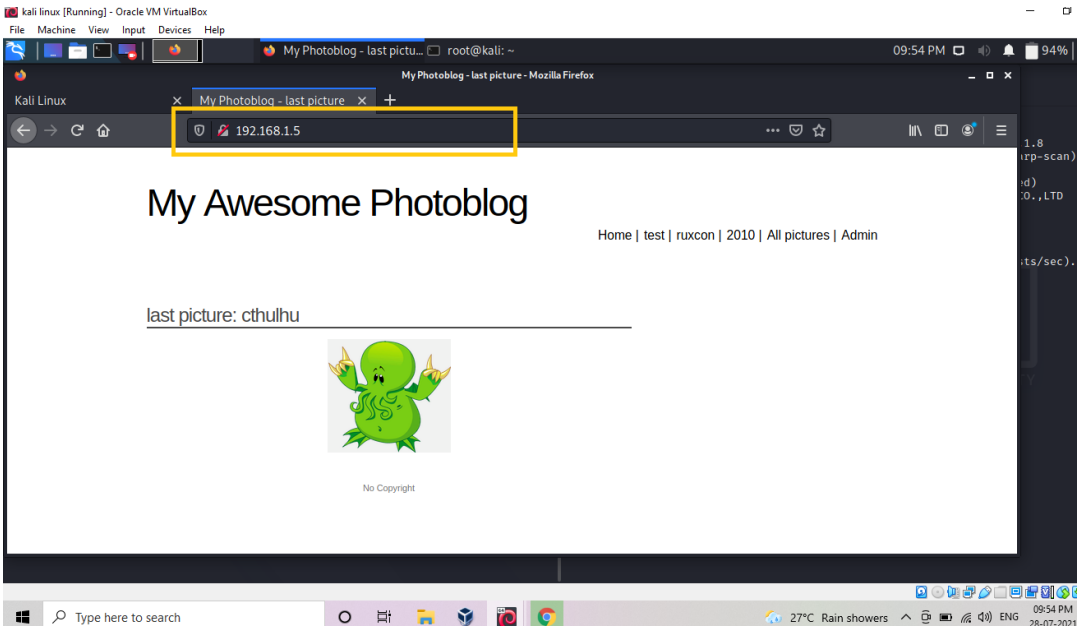


It is a **web server** so need for scanning other ports & services.
It show **open Port** of these two---

ssh - 22/tcp
http- 80/tcp

3.<u>WEB SERVER</u>

Okay, enough information from the **NMAP** let's jump strait away to the **web service**!



Nice website....
I also had a look to main **Page** and I found this, as it was their **official page**.

In the **corner** of page there was an **admin section** so I also navigated there and I was on their admin panel, but the credentials were still unknown.

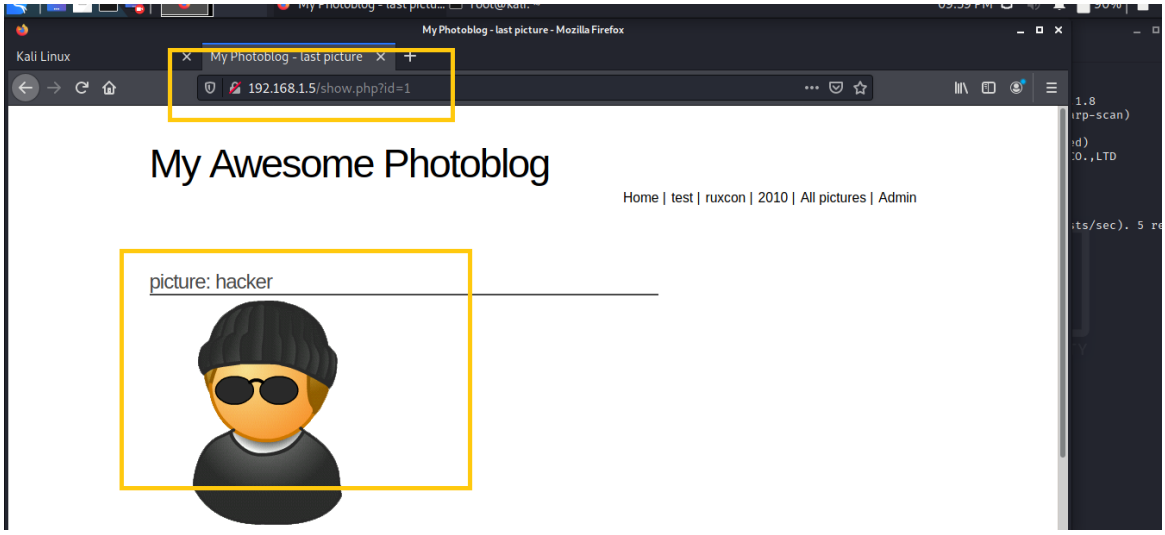
Try **SQL injection**,
we know it is related to an **SQL Injection** vulnerability so let's find this **vuln**!

Let's **visit** the pages and see if we can get something.

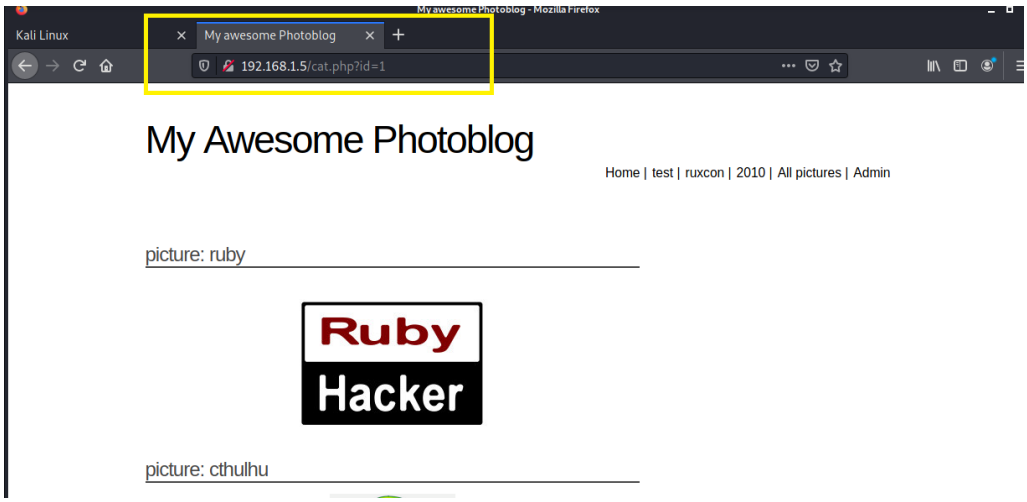
4. SQL Injection

first we find the correct id parameter and show the image.
---- 192.168.1.5/show.php?id=1

-Picture : hacker



---- 192.168.1.5/cat.php?id=1
-Picture :ruby

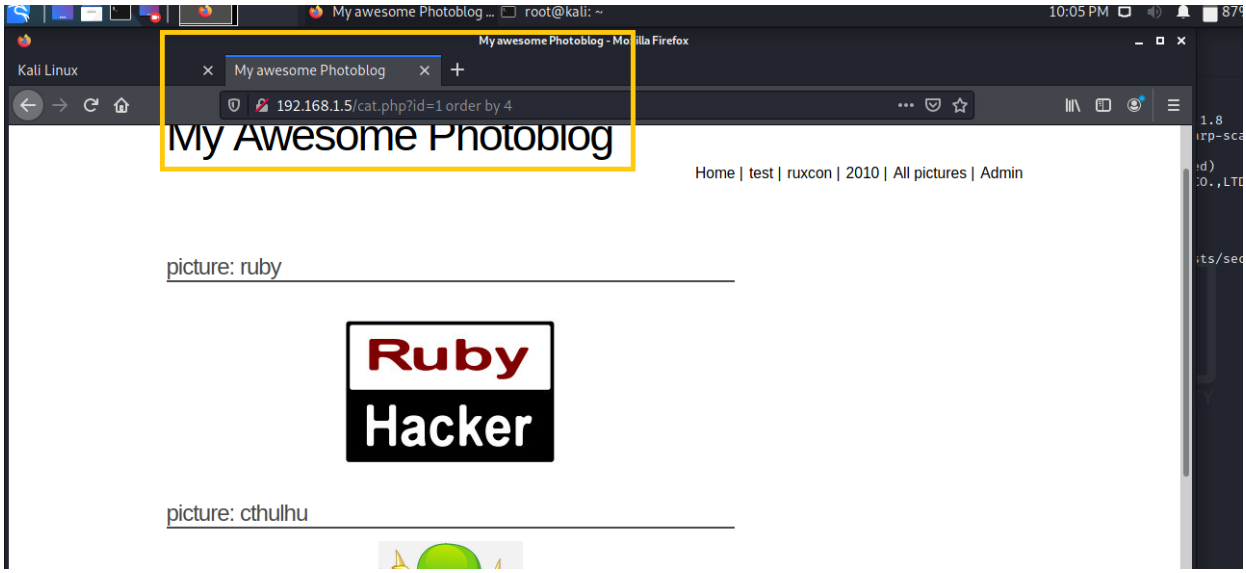


5. Enumerate : SQL Injection

Lets enumerate further by **using the browser**
Fortunately we find an SQL injection in the GET **parameter id.**

Exploiting the SQL injection to enumerate **admin credentials.**
Column number enumeration——

http:// 192.168.1.5/cat.php?id=1 order by 1
http:// 192.168.1.5/cat.php?id=1 order by 2
http:// 192.168.1.5/cat.php?id=1 order by 3
http:// 192.168.1.5/cat.php?id=1 **order by 4**



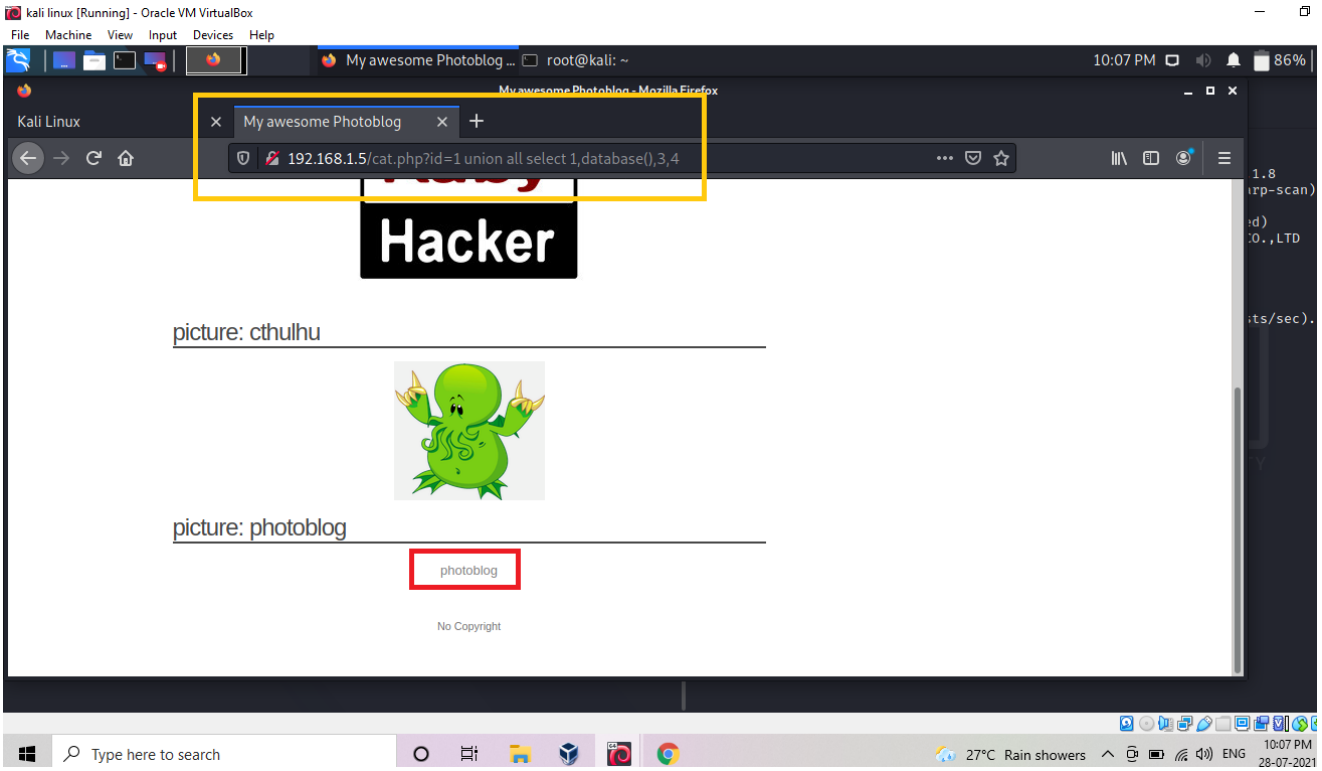
it was having **total 4 columns** as you can see **below**—

And in **fifth attempt** I got error – mean – No 5th coloumn.

So the number of columns are 4.

--Using **UNION** to select more data in one sql statement.

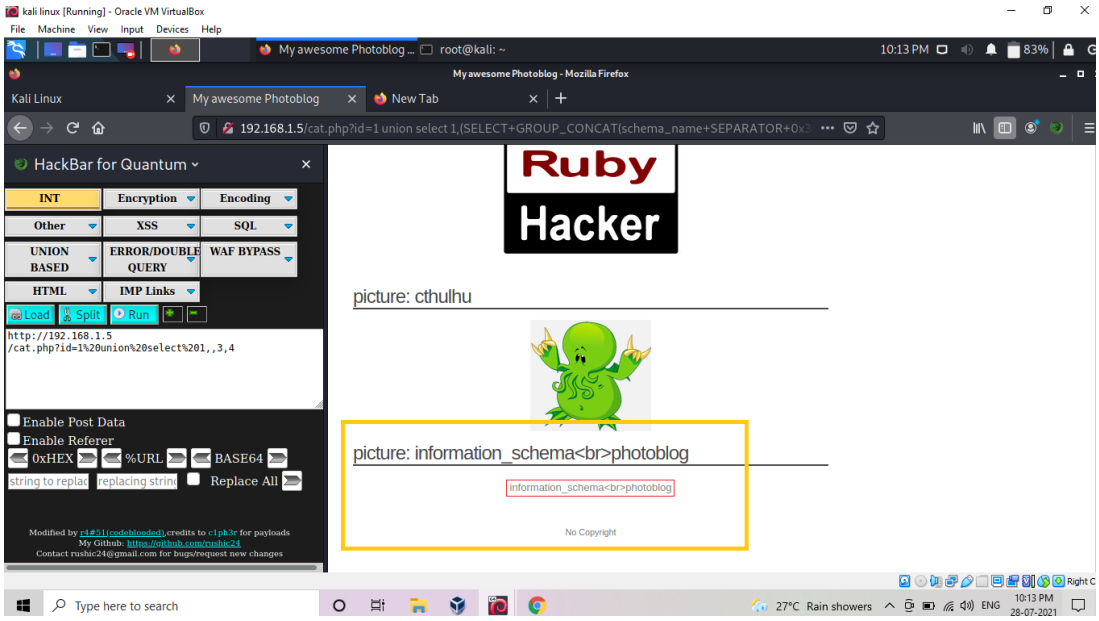
-----192.168.1.5/cat.php?id=1 union all select 1,2,3,4



And I use **HackBar** for more data found like users , log.

1. Databases

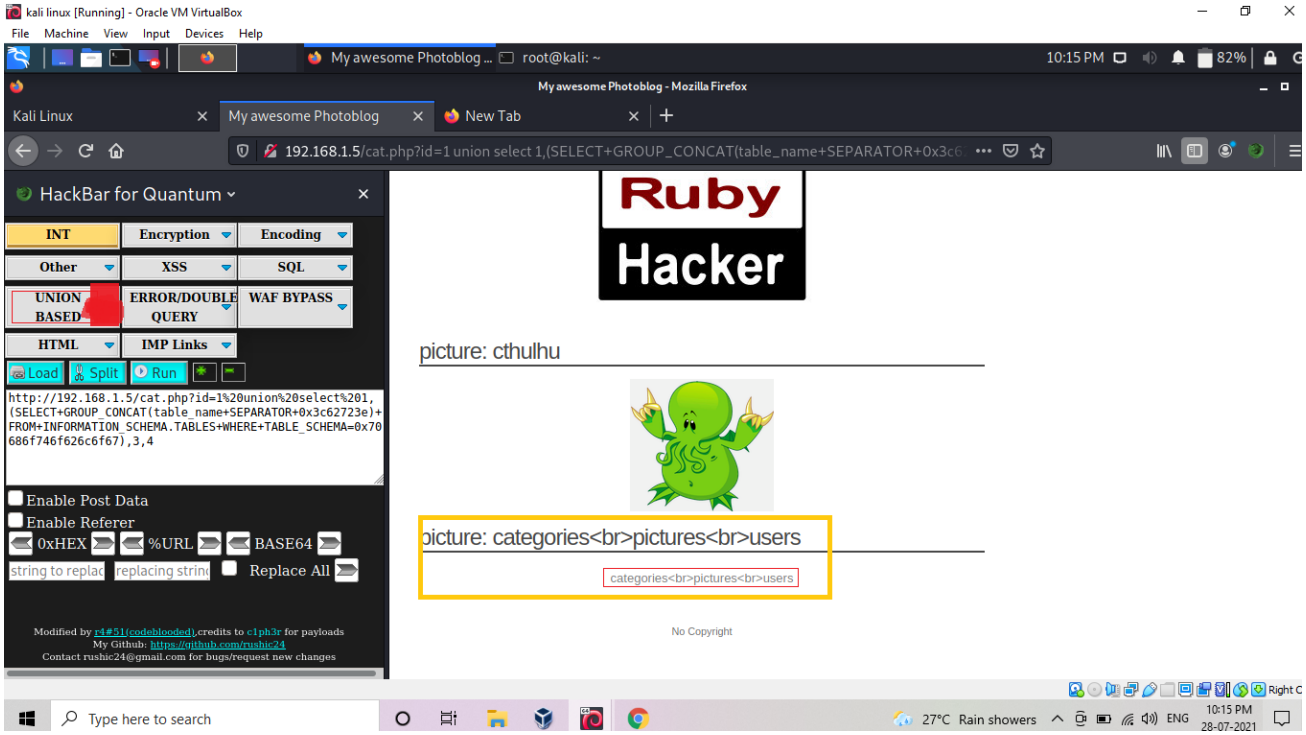
Enumerate **Photolog**



2. Tables

Enumerate table names

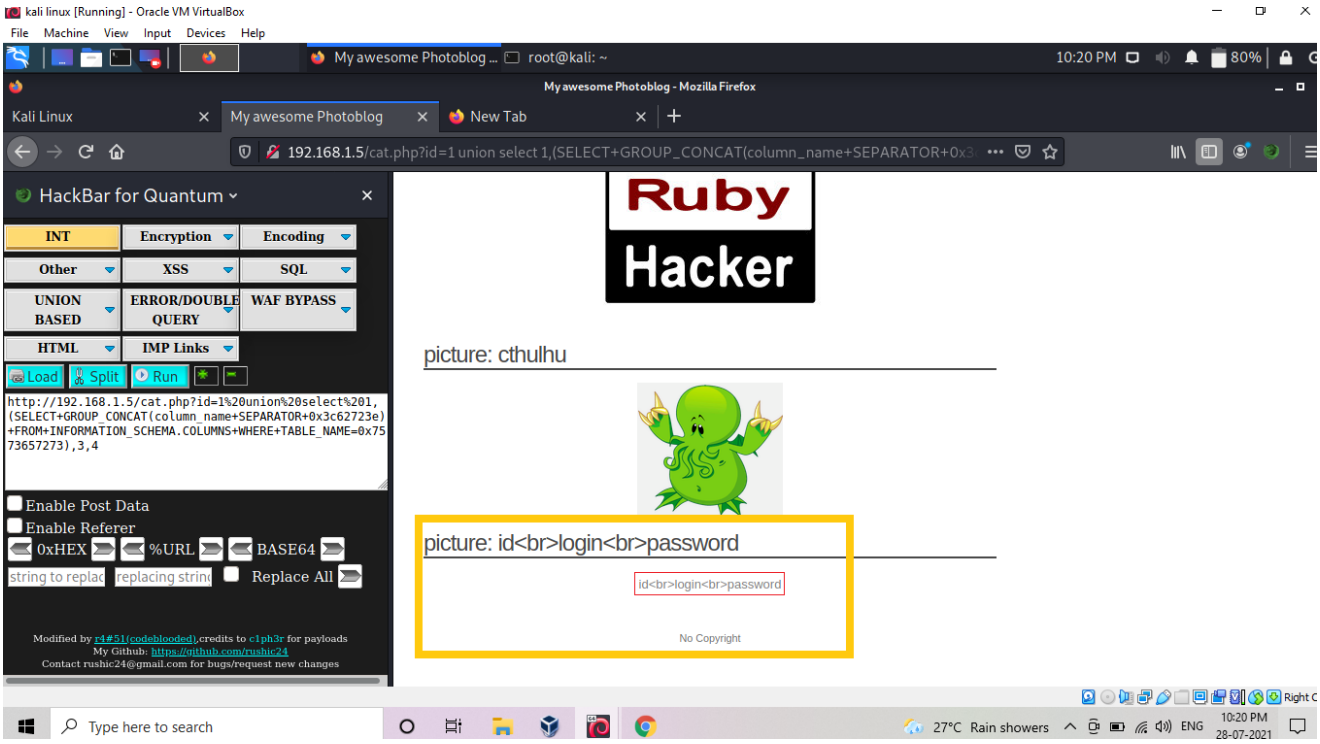
---Users



3. Coloumns

Enumerate columns of the table- ***users***

-- Id , login , password



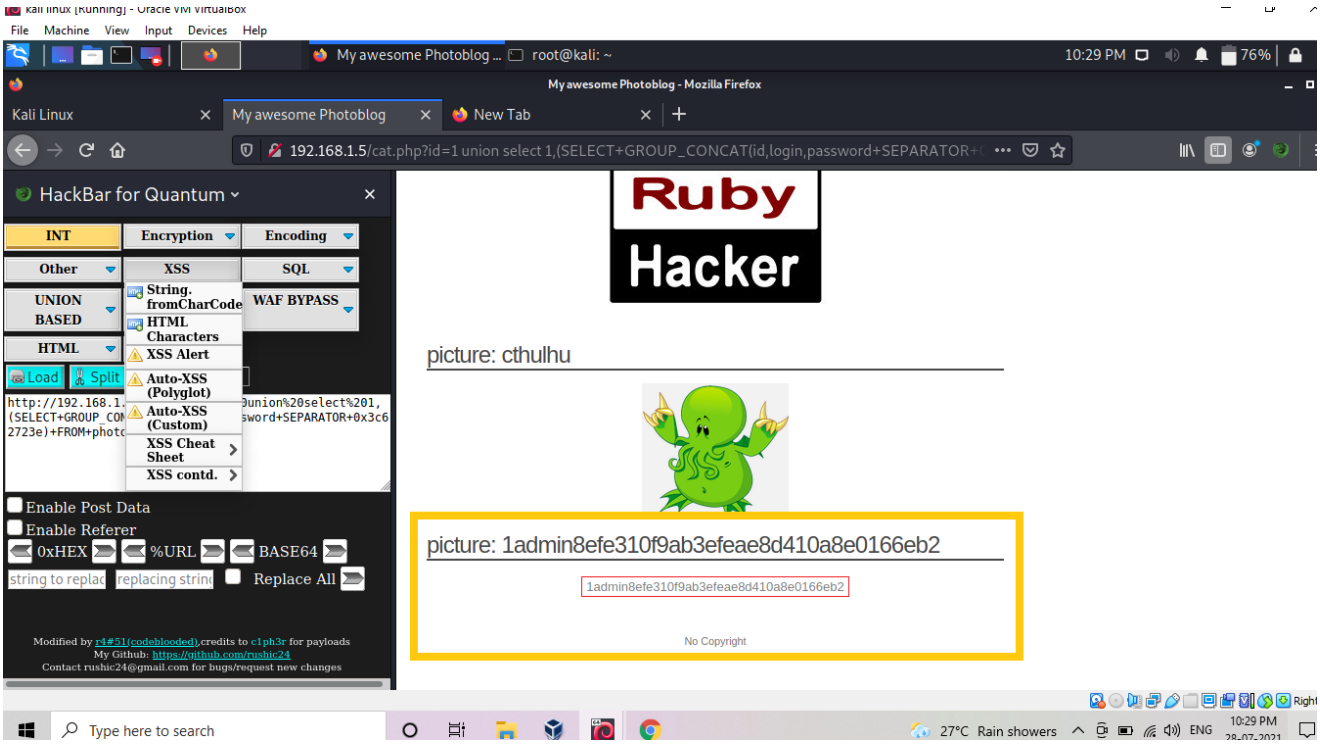
4. Data

Enumerate **Data** – it show the information

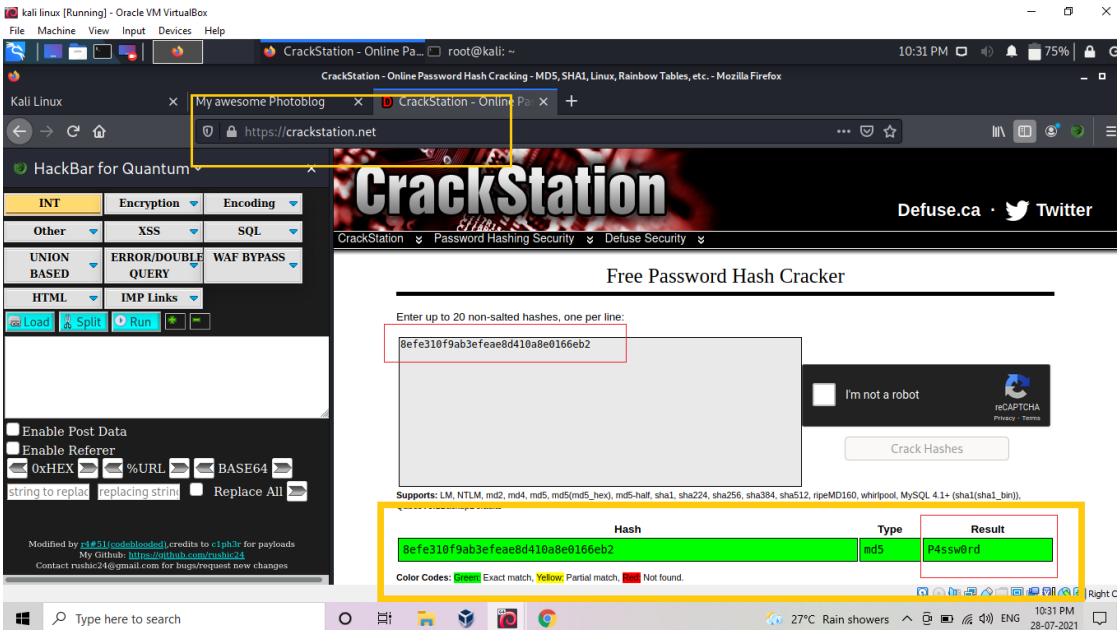
User- **Admin**

Pass- **8efe310f9ab3efeae8d410a8e0166eb2**

But Password is **Hash Mode**



Now lets crack the hash—CrackStation.

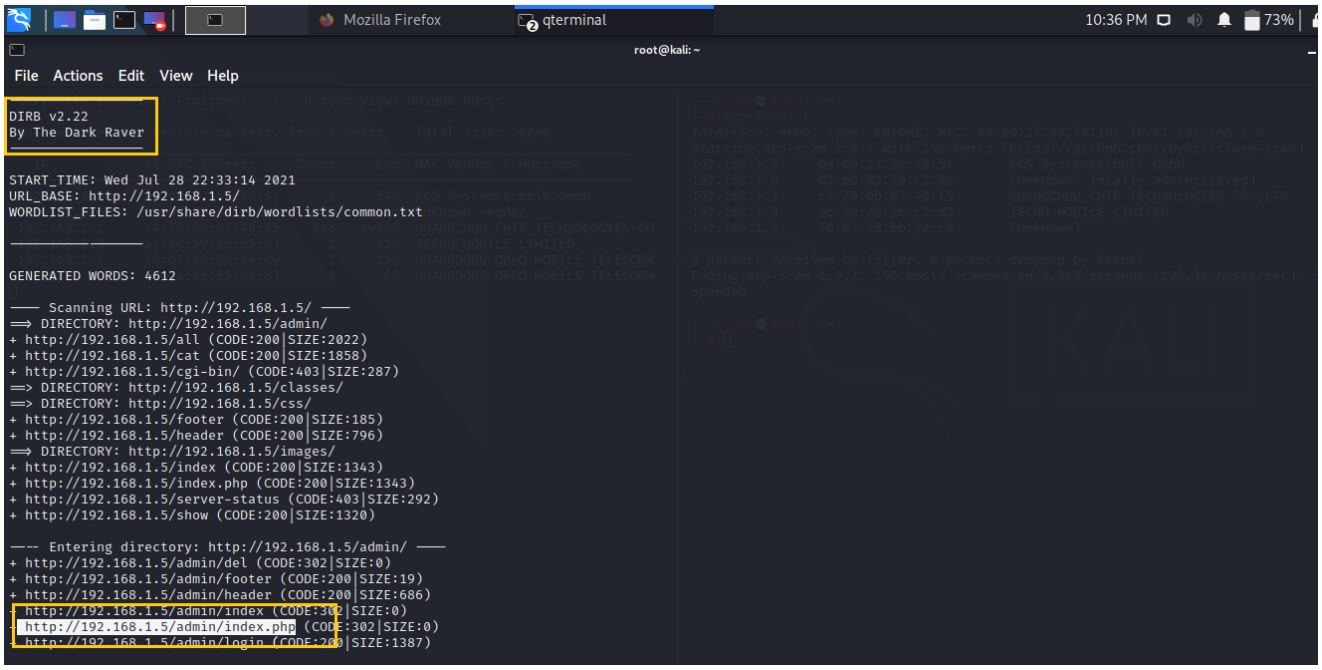


Then it found the Password.. ---- P4ssw0rd

6. finding the login Page

Run the command -Dir buster

cmd- **dirb http://192.168.1.5**



Here it Showing a link , Open in Browser

7.Log in

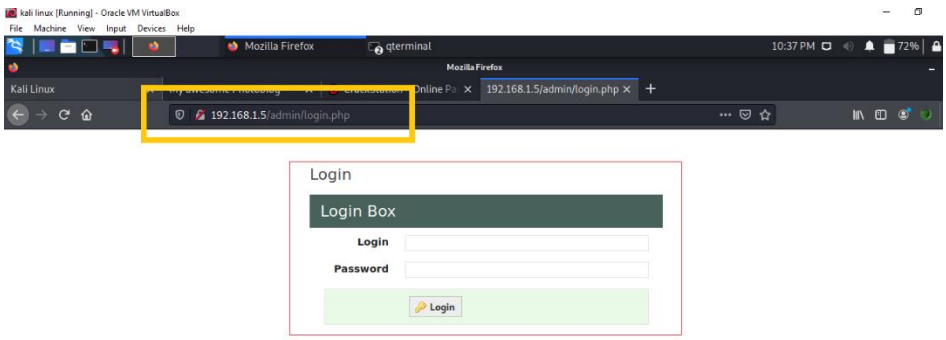
For login I am **Providing creds** like user & pass

User - **admin**

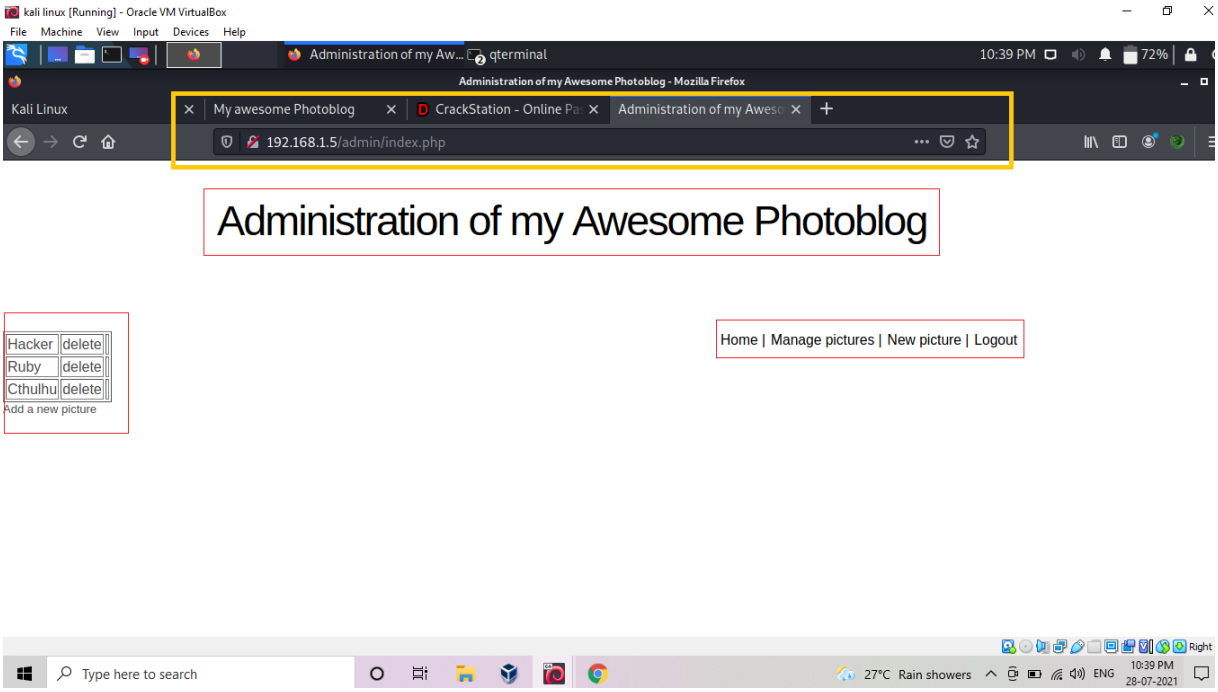
Password - **P4ssw0rd**

After **logged in** -

I navigated to **Admin page** & signed in with **creds** and all I **got** this given below

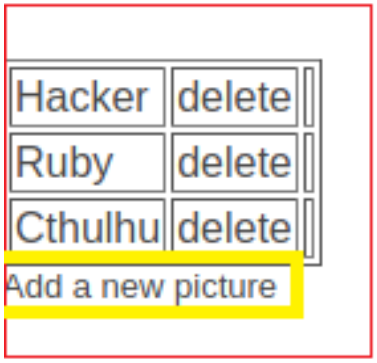


Now we are in the **administration** page :-)
----And **upload the shell** to get the **Reverse connection.**



Like we see,

We can **add a new picture** so we can **upload stuff to the server**, generally there is a **vulnerability** under the name of '**Arbitrary File Upload**'.

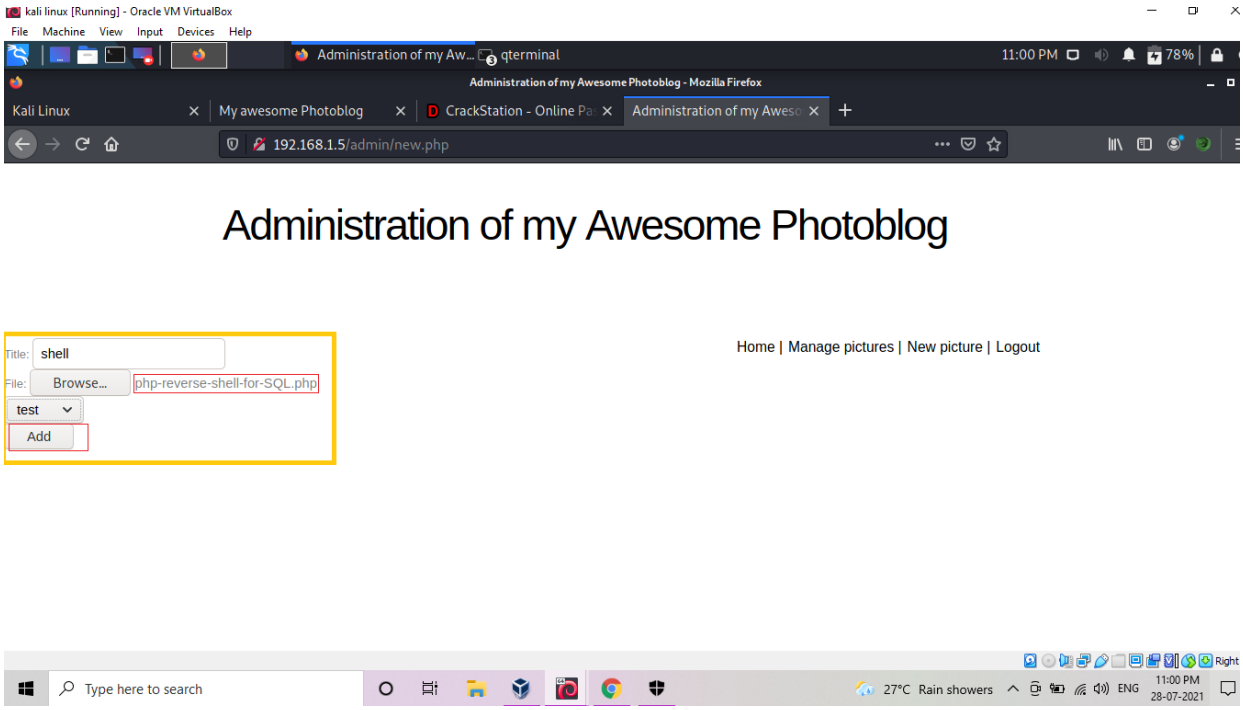


Add a new picture.

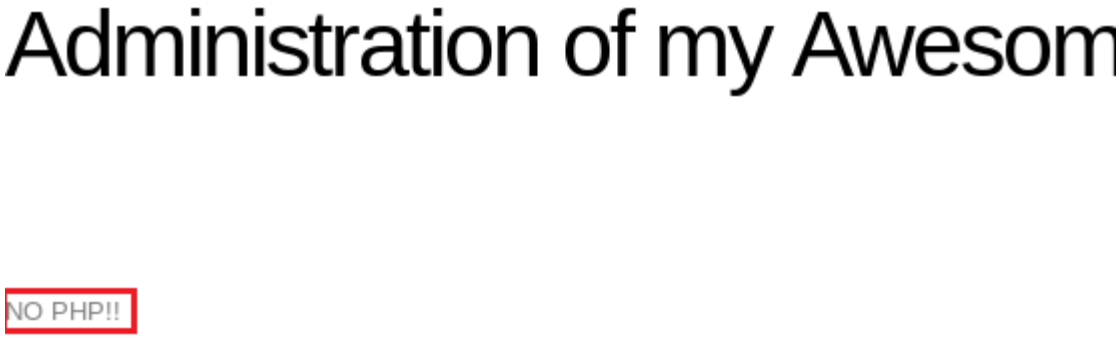
8.Upload shell

Basically it **allows** an attacker to **upload a backdoor or shell** to the web server!

Let's try it



I tried to **upload the shell** but unfortunately **failed** to upload the shell because the ***php-reverse-shell-for-SQL.php*** script seems to check for the **file extension**



It show **NO PHP** because the **file extension** does not exist.

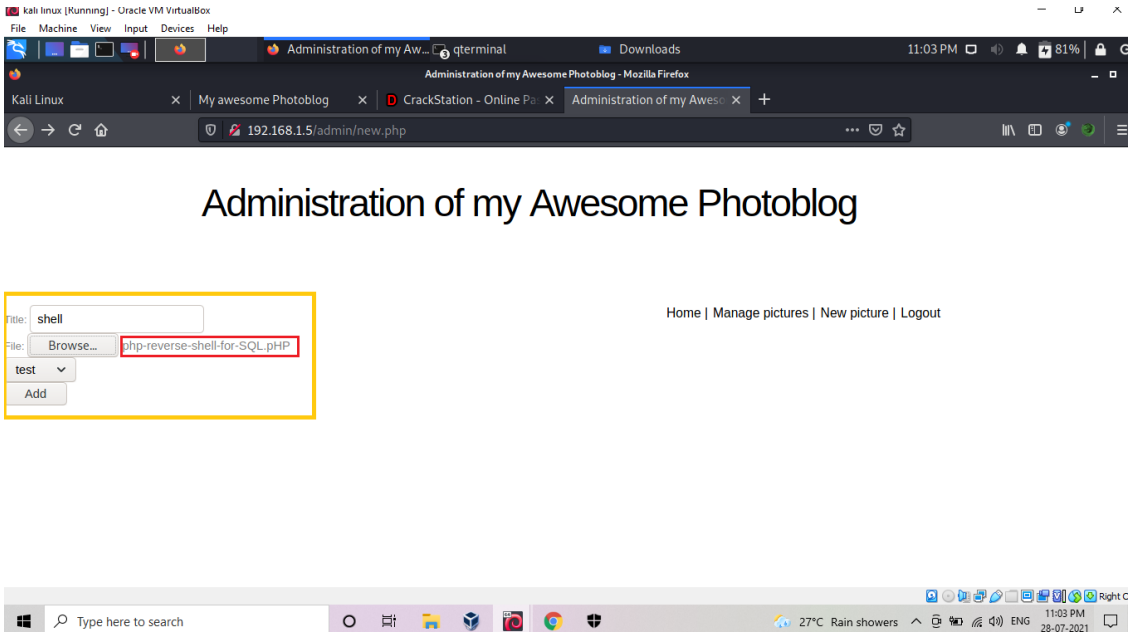
Unfortunately, I am **smarter** than the developer :-

I managed to **upload** the shell easily

By **changing the file extension to a capital one**

'.php to .pHP' , JOB is DONE :- show below-

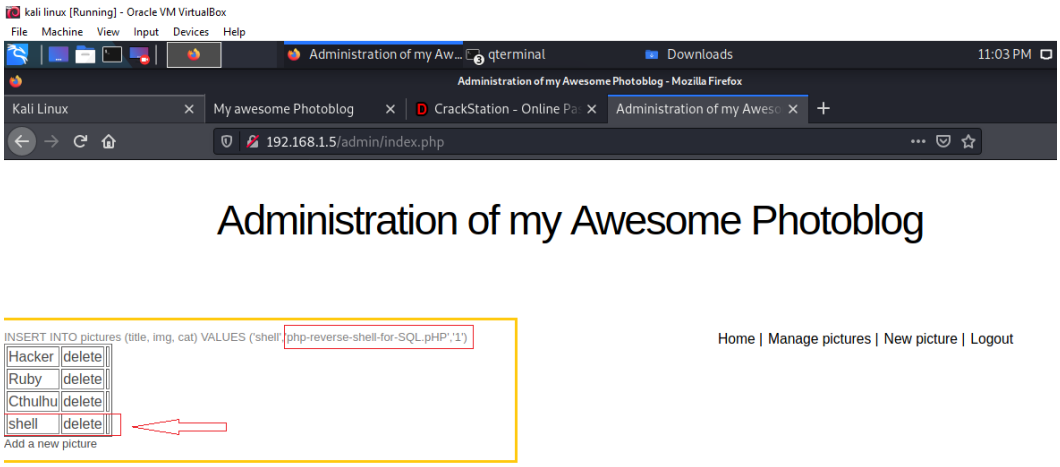
php-reverse-shell-for-SQL.php
change to this-
php-reverse-shell-for-SQL.pHP



The used shell is

--- PentestMonkey
php-reverse-shell

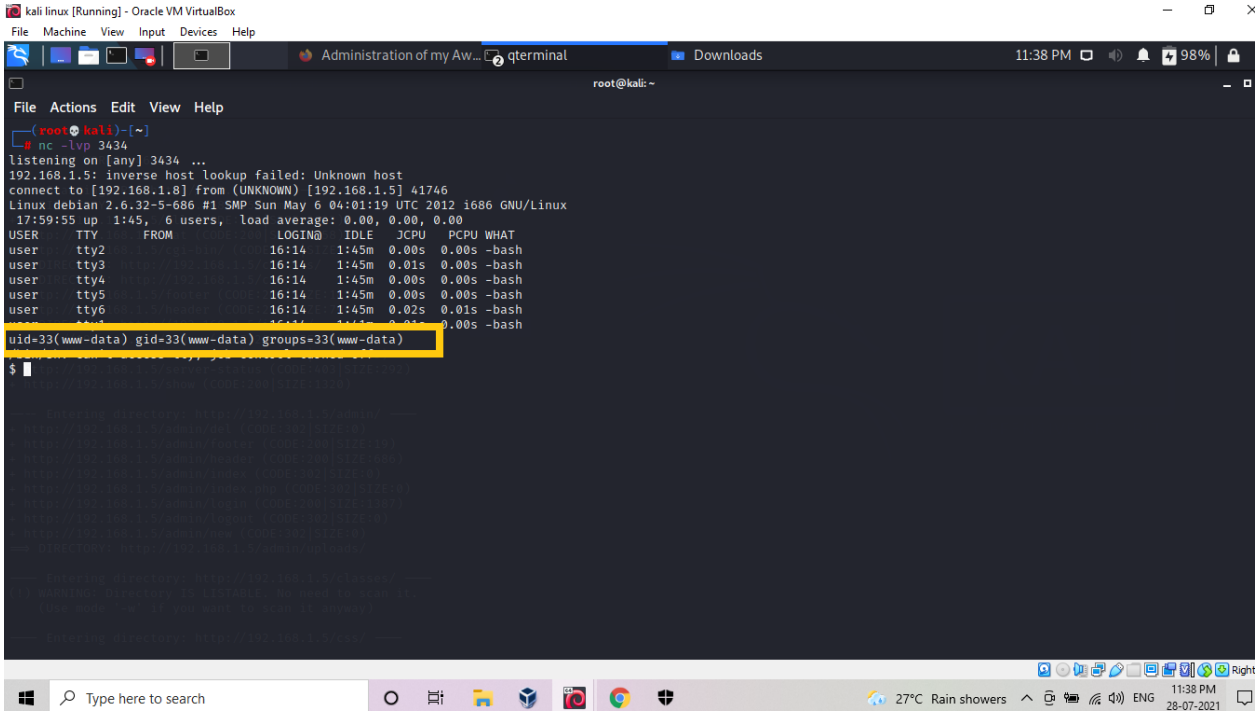
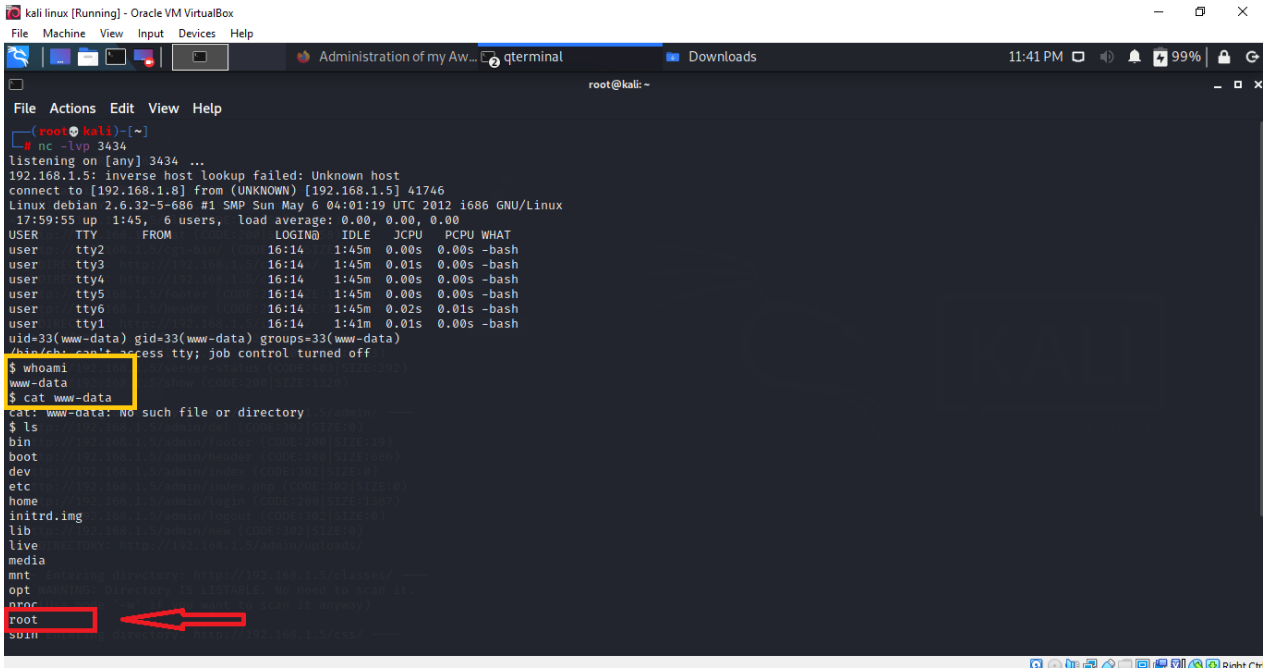
I uploaded it by the name shell and it was loaded successfully as you can see below--



Now You can see the Shell that is completely uploaded.

9. Root access

The goal was to get Shell and not to root the machine
because the user is (**www-data**), given below--



There is a chance to root the machine and it is easy;